

软件安全实验一

班级：2022211801 学号：2022211570 姓名：项枫

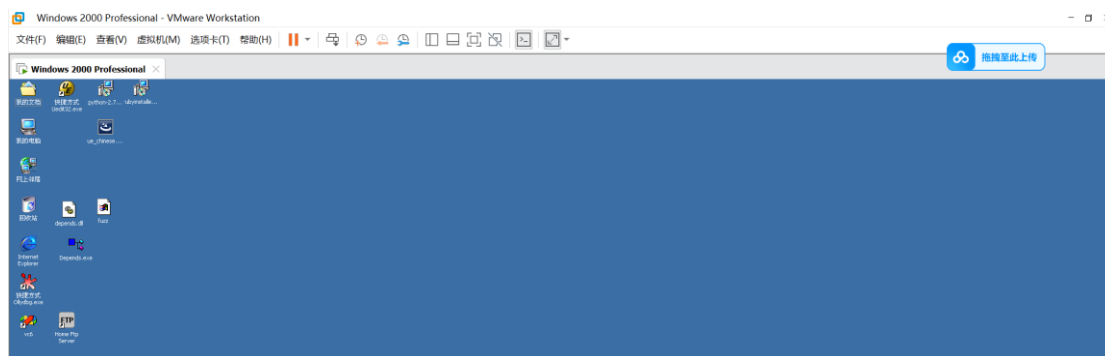
一、目标

- 1、学习 OllyDbg 基本使用知识
- 2、通过破解一个认证小程序学习与理解软件安全漏洞的基本原理
- 3、理解 PE 程序运行原理

二、测试步骤与结果

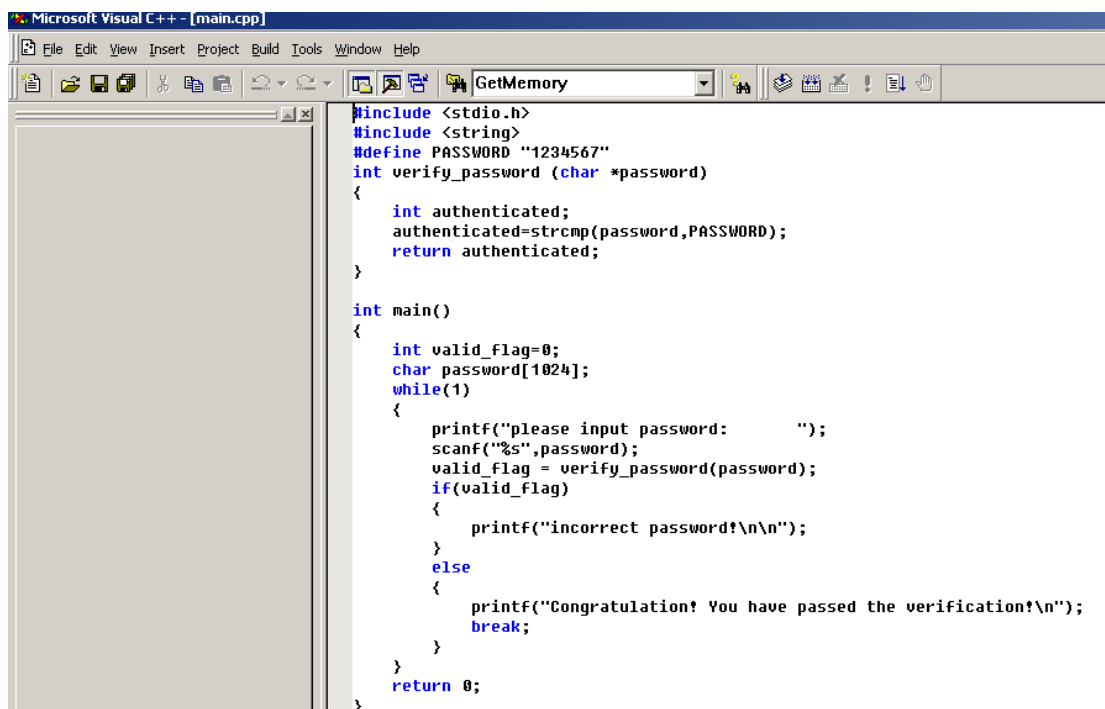
1、进入虚拟机

打开 VM workstation，点击文件->打开->选择我们要使用的 WIN2000 的 VMX 文件，之后我们就进入了虚拟机。

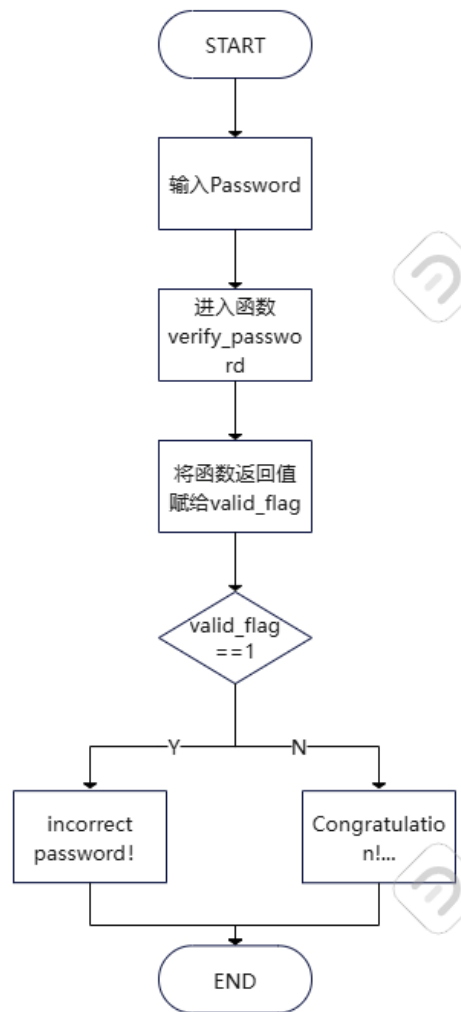


2、研究代码

使用桌面的 VC6 打开文件夹“第一次试验代码”中的 main.cpp，对代码进行研究。

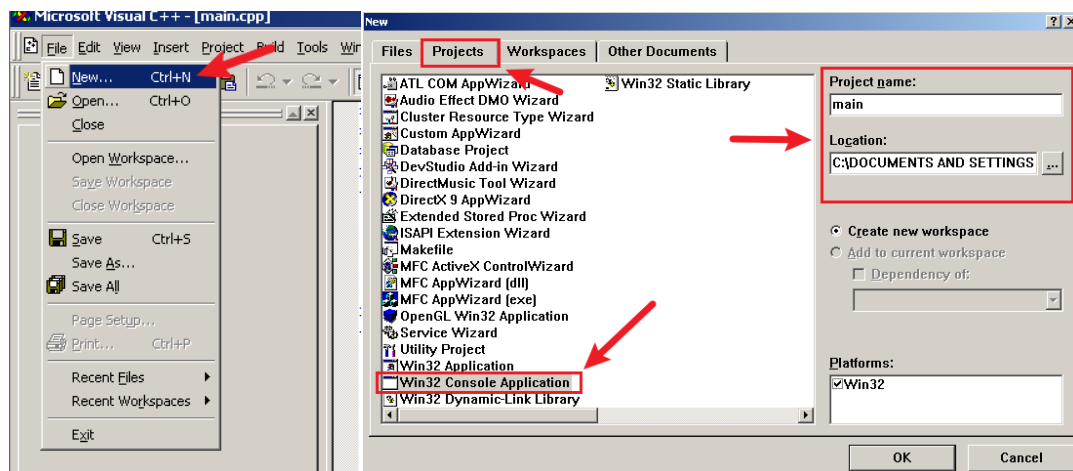


显而易见，这是一个验证输入密码是否正确的简单小程序，代码逻辑流程图如下：

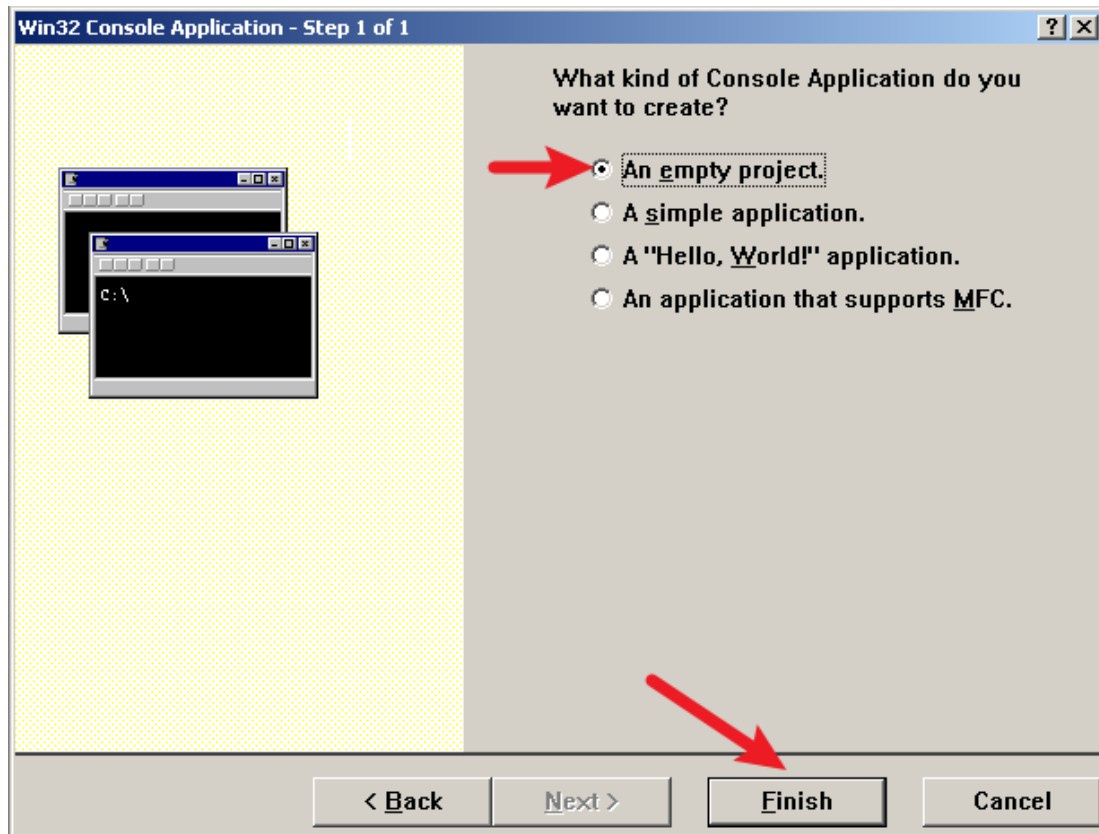


3、生成工程

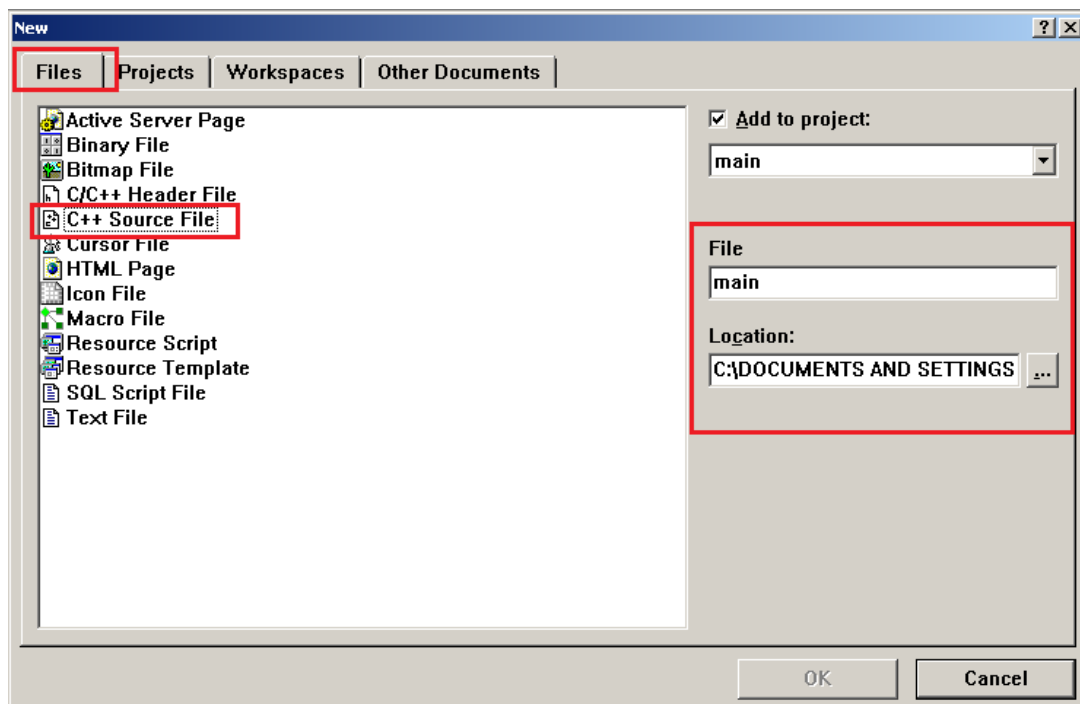
(1) 在 VC 中，点击 File->new->Projects->Win32 Console Application，右上角设置好 project 的名称和存放路径。



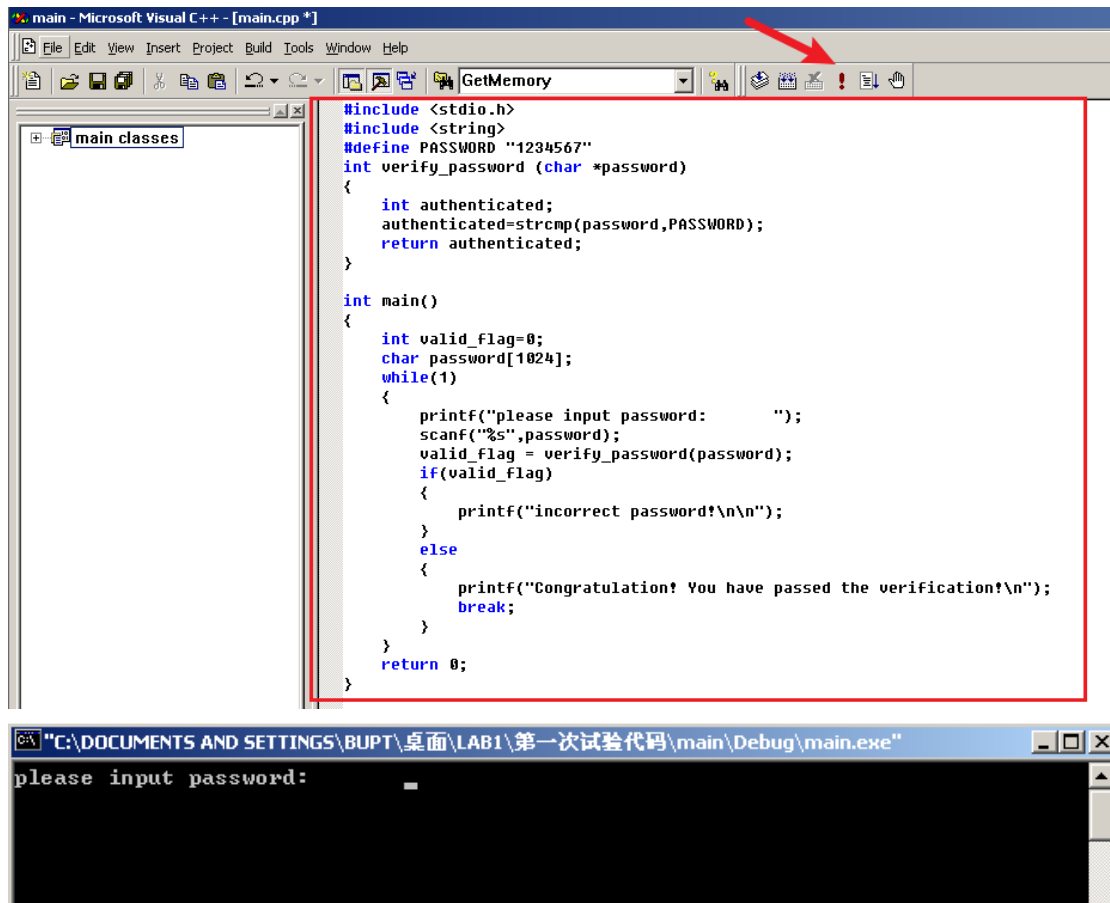
(2) 点击 OK->An empty project->Finish



(3) 之后再 new->Files->C++ Source File, 右侧设定好添加到的项目(我们刚才新建的项目), 文件名和路径。

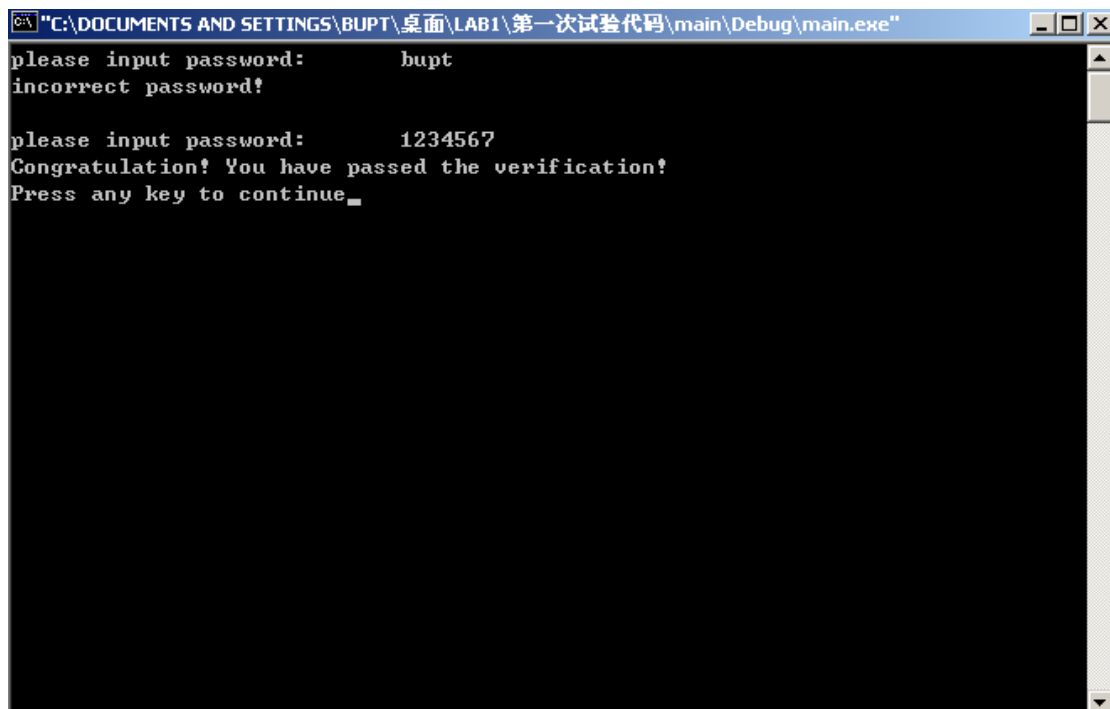


(5) 完成新建文件后, 在新建的文件下编写或复制刚才我们看到的 main 程序, 然点击右上的红色感叹号执行。



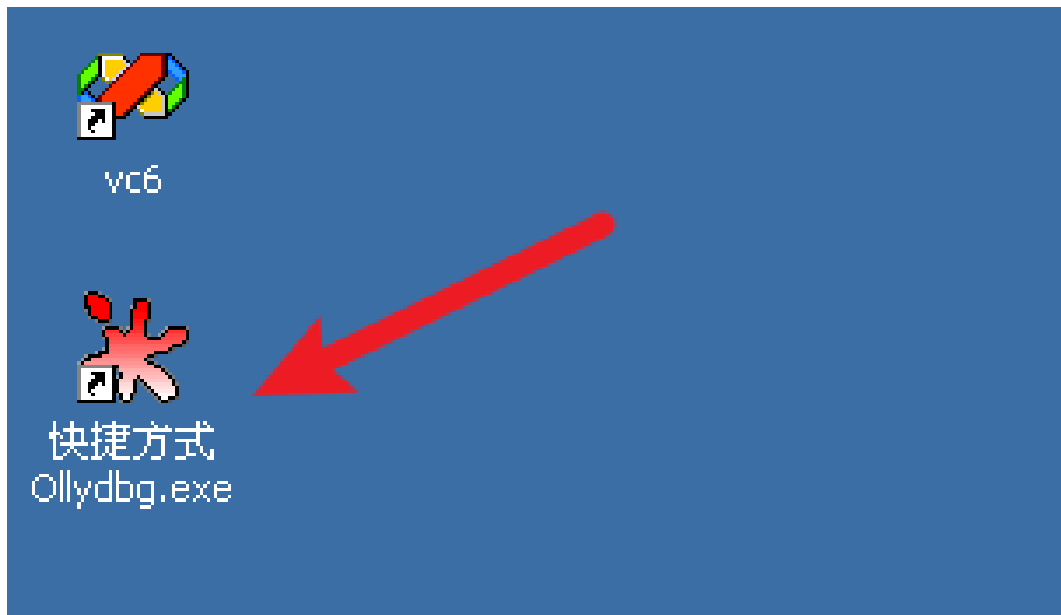
4、运行程序

程序运行后我们简单的测试一下：输入错误的密码，提示 “incorrect password!”；输入正确的密码，提示 “Congratulation!...”

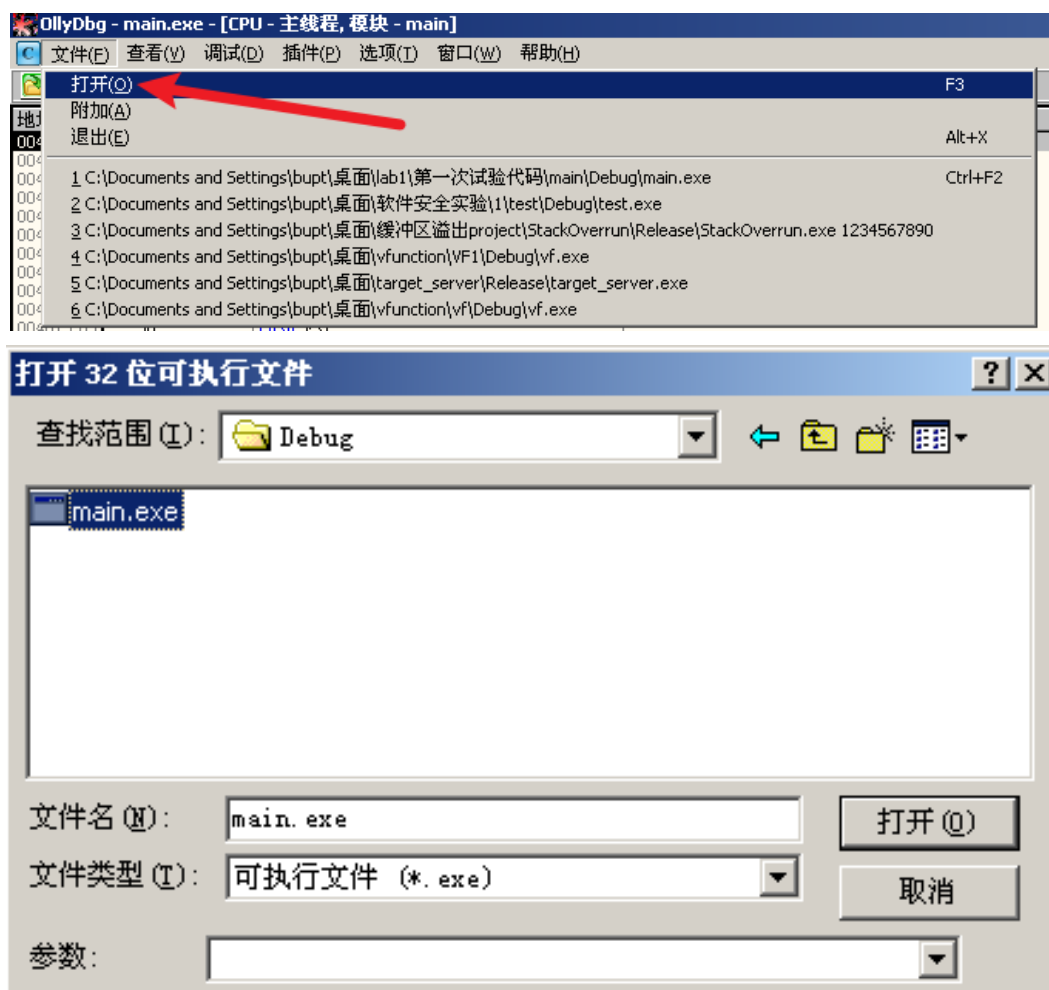


5、运行 ollydbg

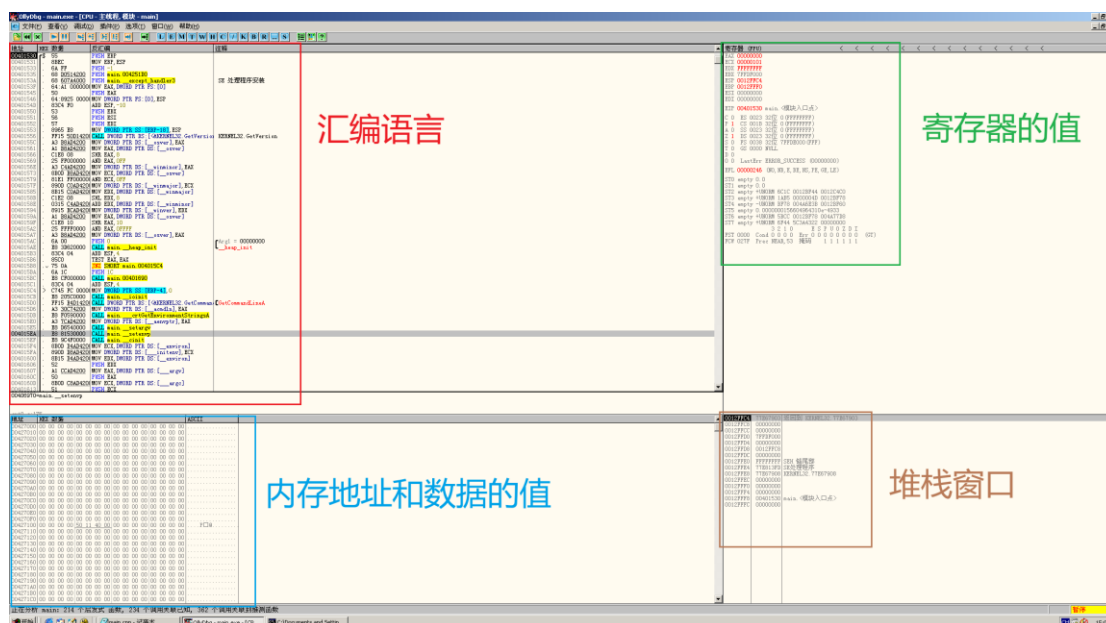
(1) 桌面找到快捷方式 ollydbg.exe，双击进入



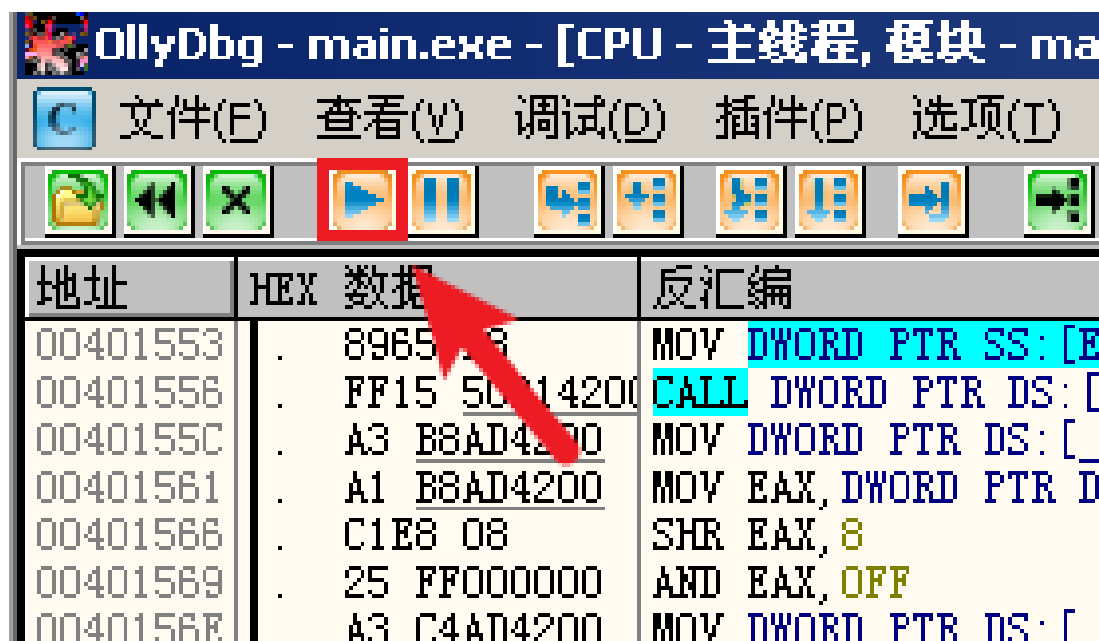
(2) 然后点击文件->打开->选择我们刚才编译生成的 exe 文件



(3) 这个 exe 文件在我们项目文件夹下的 Debug 文件夹下

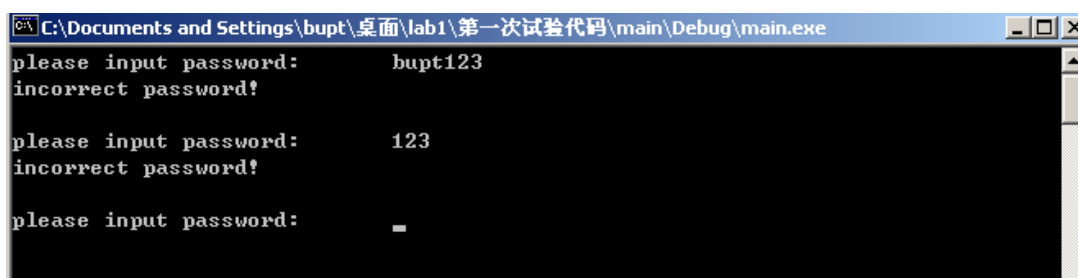


(4) 点击上面的执行按钮，播放的图标的那个按钮，开始运行程序



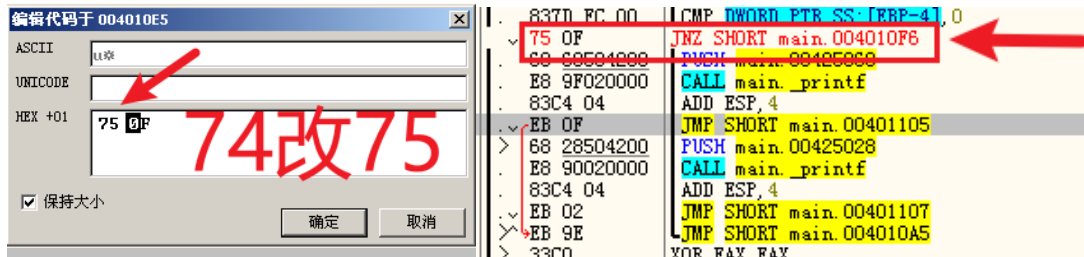
(5) 可以进行若干的密码尝试，假如要是输入了正确密码则程序自动结束

我们可以再继续打开这个 exe 来执行

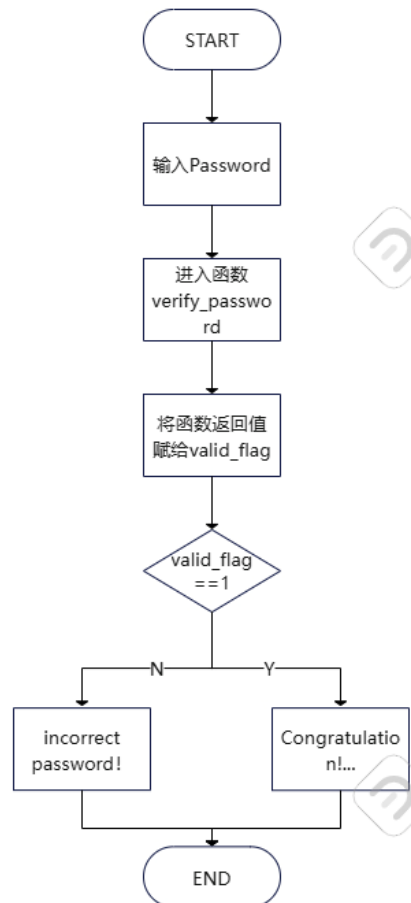


(6) 当输入一次错误的密码后，我们看 ollydbg 的调试走到了判断的区域，我们可以着重看这部分的代码

(7) 可以看到 “incorrect password ” 和 “congratulations” 两个字符串，他们所代表的是两个互斥的结果。而判断密码是否正确的判断就是这句话 JE SHORT main.004010F6 将他改成 JNE SHORT main.004010F6



6、修改原理



7、验证修改后的程序

点击运行，我们现在在输入框中输入正确的密码，观察程序反应，发现程序提示我们输入密码错误！然后我们随便输入一个错误的密码，程序提示正确，并自动退出说明我们通过改变判断条件修改了程序执行的顺序，得到了我们想要的结果验证修改。



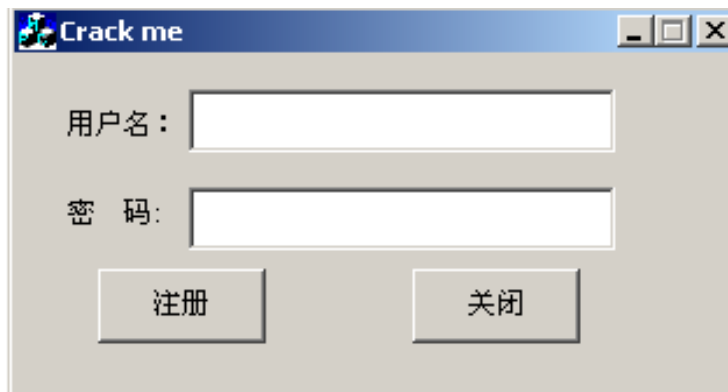
三、测试结论

只需修改一个小小的跳转条件即可实现对程序的破解，输入错误的密码提示正确，正确的密码反而提示错误。通过这次实验，我对软件安全有了更深刻的认识，也意识到软件存在着极大的安全隐患，需要我们“网安人”去保卫。

在今后的学习和工作中，编写程序时应该考虑到攻击者会进行反汇编以及修改，最好对代码进行一定的混淆。

四、思考题

1、运行 crackme.exe



2、尝试进行注册



3、进行破解

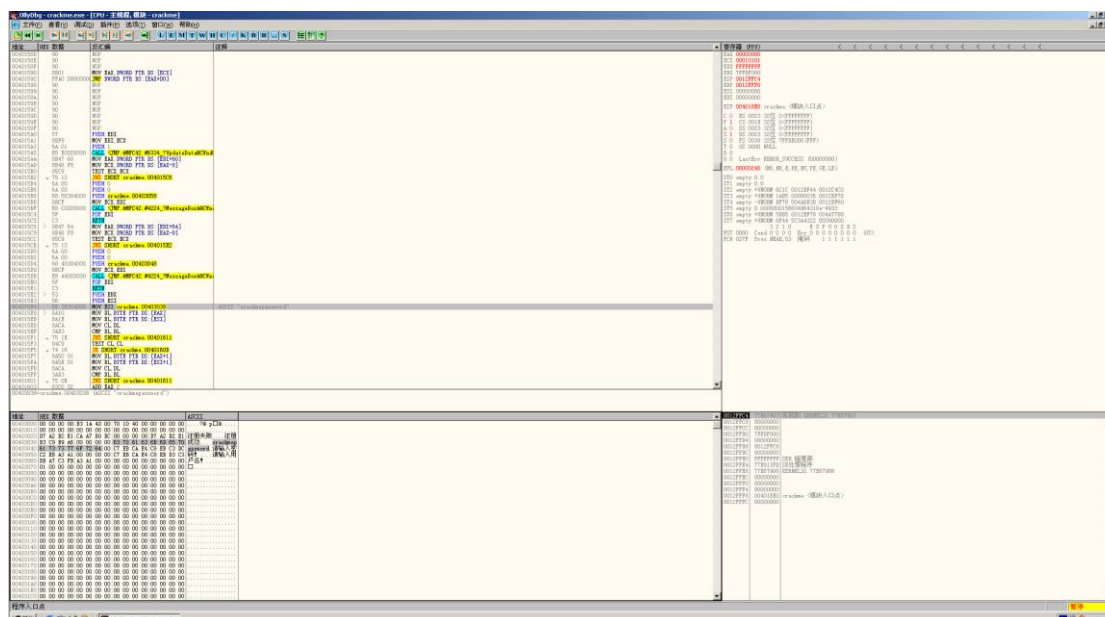
方案一：寻找密码

(1) 原理

该程序一定已经设定好了一个密码，当我们输入的值与该密码一致时，程序才会弹出“注册成功”，那么我们可以直接找这个密码。

(2) 步骤

①在 OllyDbg 中打开 crackme.exe



②寻找密码

在页面左下角的数据的值一栏可以很明显看到“注册成功”“请您输入密码!”等字样，那么我们可以大胆猜测中间的“crackmepassword”即为正确密码。

地址	HEX 数据	ASCII
00403000	00 00 00 00 B3 1A 40 00 70 10 40 00 00 00 00 00	?@.p@....
00403010	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	
00403020	D7 A2 B2 E1 CA A7 B0 DC 00 00 00 00 D7 A2 B2 E1	注册失败... 注册
00403030	B3 C9 B9 A6 00 00 00 00 63 72 61 63 6B 6D 65 70	成功... crackmep
00403040	61 73 73 77 6F 72 64 00 C7 EB CA E4 C8 EB C3 D0	assword. 请输入密
00403050	C2 EB A3 A1 00 00 00 00 C7 EB CA E4 C8 EB D3 C3	码! 请输入用
00403060	BB A7 C3 FB A3 A1 00 00 00 00 00 00 00 00 00 00	户名! 请输入
00403070	01 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	...
00403080	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	
00403090	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	
004030A0	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	
004030B0	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	

③验证猜想

用户名：crackme（任意即可）

密码：crackmepassword



可见注册成功，即证明密码为 crackmepassword，猜想正确，成功破解。

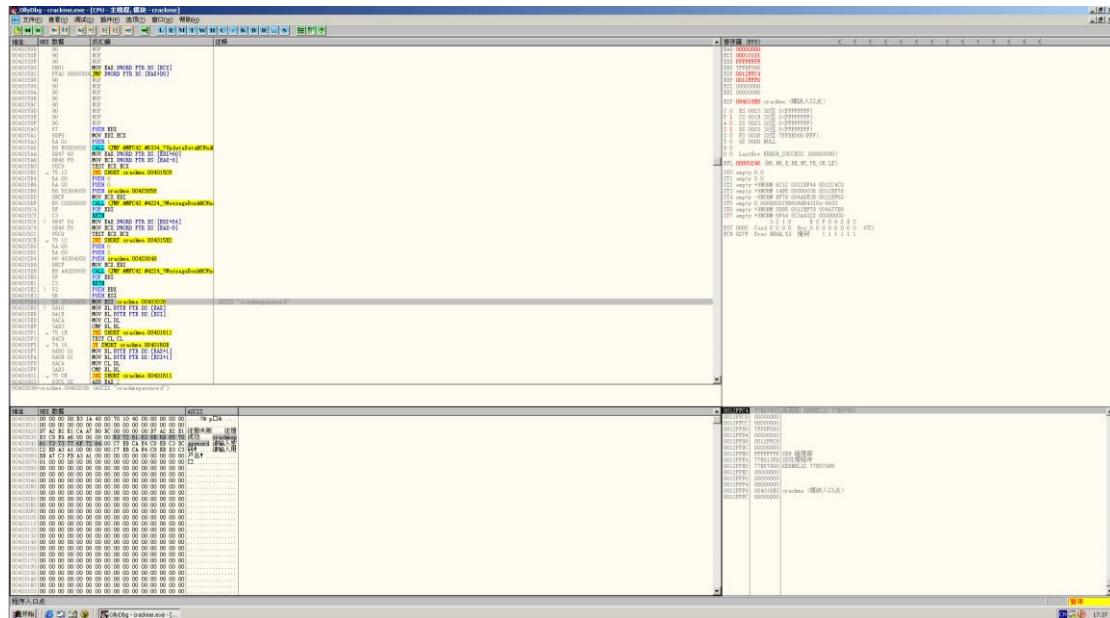
方案二：修改判断逻辑

(1) 原理

类似于上面破解认证小程序，修改判断条件，当输入错误的密码时跳转“注册成功”。

(2) 步骤

①在 OllyDbg 中打开 crackme.exe



②找寻跳转

地址	HEX 数据	汇编
0040161C	B4 00	PUSH 0
0040161E	75 17	JNZ SHORT crackme.00401637
00401620	68 2C304000	PUSH crackme.0040302C
00401625	8BCF	MOV ECX, EDI
00401627	E8 58020000	CALL <JMP.&MFC42.#4224_?MessageBoxA@CWnd>
0040162C	6A 00	PUSH 0
0040162E	8BCF	MOV ECX, EDI
00401630	E8 55020000	CALL <JMP.&MFC42.#6334_?UpdateData@CWnd>
00401635	5F	POP EDI
00401636	C3	RETN
00401637	68 20304000	PUSH crackme.00403020
0040163C	8BCF	MOV ECX, EDI
0040163E	E8 41020000	CALL <JMP.&MFC42.#4224_?MessageBoxA@CWnd>
00401643	8B07	MOV EAX, DWORD PTR DS:[EDI]
00401645	8BCF	MOV ECX, EDI
00401647	FF90 D0000000	CALL DWORD PTR DS:[EAX+D0]
0040164D	6A 00	PUSH 0
0040164F	8BCF	MOV ECX, EDI
00401651	E8 34020000	CALL <JMP.&MFC42.#6334_?UpdateData@CWnd>
00401656	5F	POP EDI

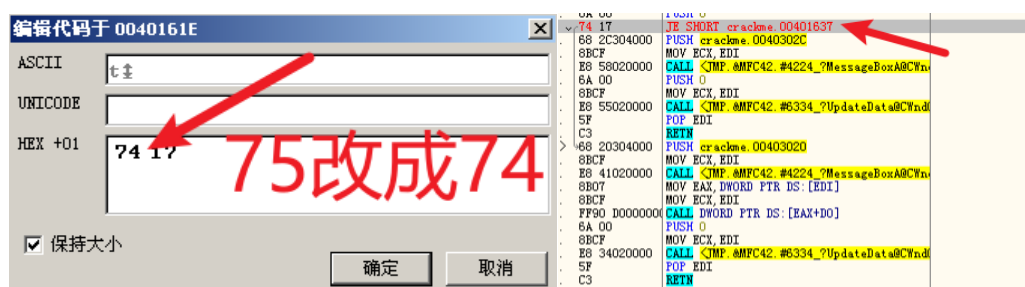
00401637=crackme.00401637

地址	HEX 数据	ASCII
00403000	00 00 00 00 B3 1A 40 00 70 10 40 00 00 00 00 00	?@.p[...]
00403010	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	
00403020	D7 A2 B2 E1 CA A7 B0 DC 00 00 00 00 D7 A2 B2 E1	注册失败...注册
00403030	B3 C9 B9 A6 00 00 00 00 63 72 61 63 6B 6D 65 70	成功...crackme
00403040	61 73 73 77 6F 72 64 00 C7 EB CA E4 C8 EB C3 DC	...rd. 请输入密
00403050	C2 EB A3 A1 00 00 00 00 C7 EB CA E4 C8 EB D3 C3	码! ... 请输入用
00403060	BB A7 C3 FB A3 A1 00 00 00 00 00 00 00 00 00	户名! ...
00403070	01 00 00 00 00 00 00 00 00 00 00 00 00 00 00	□.....
00403080	00 00 00 00 00 00 00 00 00 00 00 00 00 00 00	

由上图可知，JNZ SHORT crackme.00401637 即为注册成功/失败判断跳转。

③ 破解程序

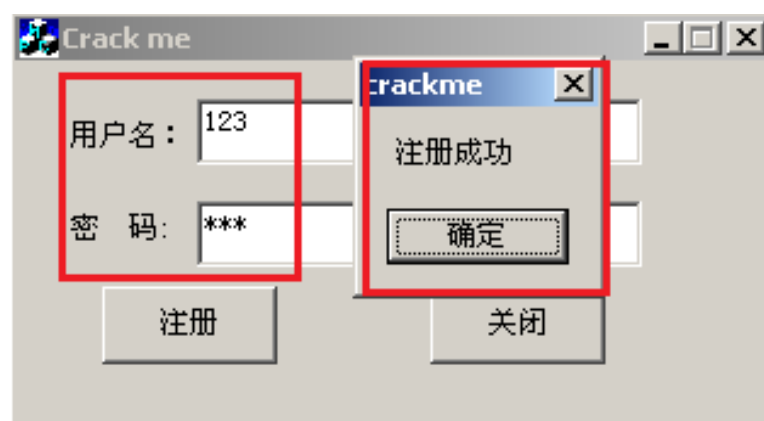
将 JNZ SHORT crackme.00401637 改成 JE SHORT crackme.00401637。



④ 验证破解

用户名：123（任意即可）

密码：123（任意非正确密码即可）



输入不正确的密码，也提示“注册成功”，即破解成功。修改后的程序保存为 crackme_break.exe。